Hardening Windows

Automação segura e rastreável de 16 controles de segurança

Sofia Queiroz, Mateus Cunha, Vinícius Ribeiro
Sistemas Operacionais 2026.2 · Prof.ª Tarciana Dias da Silva

Implementação acadêmica e prática, com validação real em VM

Três frentes, responsabilidades distintas

Checklist

Rodrigo Campos

Gabriel Cortez

Definem os controles e as justificativas.

Automação

Este projeto

Transforma medidas viáveis em auditoria e aplicação controlada.

Riscos e ataques

Caio Tenório

Tiago Gaspar

Recebem tabela de controles e evidências.

Interlocução com ATI-PE + abordagem aceita pela professora

Segurança precisa preservar os serviços

Disponibilidade

Bloqueios e firewall podem interromper usuários e administração remota.

Compatibilidade

Versão, edição e GPO alteram os recursos e a política efetiva.

Manutenção

Mudanças precisam de responsável, aprovação e evidência recuperável.

Aplicar com segurança exige conhecer o cenário da VM.

Objetivo: conhecer, mudar com controle e comprovar

Conhecer

Auditar 16 IDs e comparar estado observado com perfil acadêmico.

Controlar

Aplicar somente o escopo implementado, aprovado e protegido por backup.

Comprovar

Verificar novamente, exportar resultados e registrar limites da recuperação.

Laboratório proposto: Win 10/11 Pro ou Windows Server compatível; Não funciona no Win 8 ou mais antigo

Visão geral: exatamente 16 controles

AUTENTICAÇÃO

01 Senha mínima ≥ 12
02 Complexidade
03 Histórico ≥ 5
04 Validade ≤ 90 dias
05 Bloqueio após 5
06 Duração ≥ 15 min

IDENTIDADES E ACESSO

07 Administrador: SID -500
08 Convidado: SID -501
09 UAC elevado
10 Logon de rede local

RASTREABILIDADE

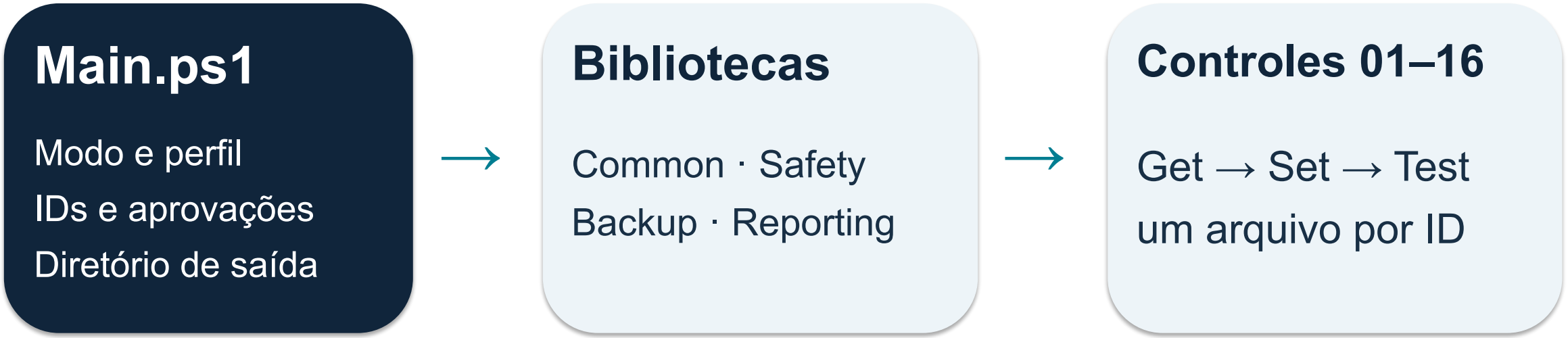
11 Auditoria de logon
12 Firewall e portas
13 Proteção de logs
14 Contas e grupos

SUPERFÍCIE

15 Apps e recursos
16 Serviços e contas

Escopo contextual: somente auditoria em 10, 12, 13 e 16

Arquitetura modular, um ponto de entrada



Saídas: inventários antes/depois · JSON · CSV · HTML/Markdown · backup com escopo

A mudança é uma etapa, não o ponto de partida

1	2	3	4	5
AUDITAR	**PROTEGER**	**AUTORIZAR**	**APLICAR**	**VERIFICAR**
Estado antes	Snapshot + backup	VM + IDs + escopo	ShouldProcess	Estado depois

Audit é o padrão. Whatlf permite simular decisões. Backup local ≠ snapshot externo da VM.

Rollback limitado à configuração suportada; divergências posteriores exigem revisão.

01–06 · Autenticação e limitação de tentativas

scripts/controles/01-SenhaMinima.ps1:31

```
$target = [int]$Context.Config.Password.MinimumPasswordLength
if ($PSCmdlet.ShouldProcess('Política de senha local', "MinimumPasswordLength=$target")) {
    Set-HWSecurityValues -Context $Context -Values @{ MinimumPasswordLength = $target }
```

O COMANDO FAZ

Lê a diretiva e prepara alteração mínima, após aprovação.

CONCEITO DE SO

A base de políticas persiste regras de autenticação e bloqueio.

RISCO REDUZIDO

Senhas frágeis e tentativas repetidas; atenção à negação de serviço.

Checklist: complexidade e rotação em 90 dias; recomendações modernas pedem revisão.

07–10 · Identidade, tokens e fronteiras de confiança

scripts/controles/07-RenomearAdministrador.ps1:79

```
if ($PSCmdlet.ShouldProcess($current.Observed.SID, 'Renomear a conta interna Administrador')) {
    Rename-LocalUser -SID $current.Observed.SID -NewName $desired -ErrorAction Stop
```

O COMANDO FAZ

Renomeia a identidade -500, preservando seu SID.

CONCEITO DE SO

SID identifica a conta; grupos e tokens determinam privilégios.

RISCO REDUZIDO

Tentativas pelo nome conhecido; medida complementar, sem ocultar o SID.

08: Convidado -501 desabilitado · 09: UAC/área segura · 10: rede local somente auditada.

11 · Auditoria transforma eventos em rastreabilidade

scripts/controles/11-AuditoriaLogon.ps1:68

```
$guid = '{0CCE9215-69AE-11D9-BED3-505054503030}'
if ($PSCmdlet.ShouldProcess('Auditoria da subcategoria Logon', 'Habilitar sucesso e falha')) {
    Set-HWAuditPolicy -Context $Context -Guid $guid -Value 3
```

O COMANDO FAZ

Consulta subcategoria por GUID e habilita somente o escopo aprovado.

CONCEITO DE SO

O serviço de eventos registra decisões de autenticação conforme a política.

RISCO REDUZIDO

Tentativas sem registro; logs apoiam detecção e investigação.

4624 / 4625: logon · 4740: bloqueio; dependem da subcategoria e da origem do evento.

12 · Firewall e portas: observar antes de restringir

scripts/controles/12-FirewallEPortas.ps1:6

```
$profiles = @(Get-NetFirewallProfile -PolicyStore ActiveStore -ErrorAction Stop |
    Select-Object Name, Enabled, DefaultInboundAction, DefaultOutboundAction)
$tcp = @(Get-NetTCPConnection -State Listen -ErrorAction Stop |
```

O COMANDO FAZ

Inventaria perfis efetivos, exceções e sockets em escuta.

CONCEITO DE SO

Firewall filtra a pilha de rede; porta identifica o ponto de serviço.

RISCO REDUZIDO

Exposição desnecessária e movimento lateral entre máquinas.

Somente auditoria: Domain/Private/Public, entrada padrão, regras e administração remota.

13–14 · Proteger a evidência e revisar privilégios

scripts/controles/13-ProtecaoLogs.ps1:8

```
$acl = Get-Acl -LiteralPath $logsPath -ErrorAction Stop
$channels = @(Get-WinEvent -ListLog @('Security','System') -ErrorAction Stop |
    Select-Object LogName, IsEnabled, MaximumSizeInBytes, LogMode, SecurityDescriptor)
```

O COMANDO FAZ

Lê ACLs e direitos sem substituir permissões de serviços.

CONCEITO DE SO

ACL limita ações; direitos e grupos influenciam tokens administrativos.

RISCO REDUZIDO

Limpeza de rastros e persistência por novas contas privilegiadas.

13: auditar ACL e limpeza · 14: auditar direitos; aplicar apenas subcategorias de auditoria.

15–16 · Menos componentes, menos exposição

scripts/controles/15-AplicacoesERecursos.ps1:81

```
$result = Disable-WindowsOptionalFeature -Online -FeatureName $name -NoRestart -ErrorAction Stop
$changed = $true
if ($result.RestartNeeded) { $restart = $true }
```

O COMANDO FAZ

Inventaria recursos e aplicações; ação limitada a features aprovadas.

CONCEITO DE SO

Processos e serviços usam contas, inicialização e dependências.

RISCO REDUZIDO

Componentes legados e credenciais de serviço sem manutenção.

15: só features presentes e aprovadas · 16: serviços e dependências apenas auditados.

O que foi entregue e o que ainda falta validar

Entregáveis

Relatório, matriz, PPTX e scripts modulares.

Código sem validação real em Windows.

Verificação local

Linux: estrutura, contratos estáticos e artefatos.

PowerShell e testes com mocks: pendentes.

Laboratório

Auditoria e aplicação em VM: pendentes.

Sem medições, prints ou eficácia inventados.

Rede GitHub depende do proxy do ambiente; commit/push devem ser conferidos no status de execução.

Próximos passos: validar com quem opera

1 · Escopo

Confirmar equipe, agenda e perfil com a professora e a ATI-PE.

2 · Laboratório

Aprovar VM, snapshot, conta de recuperação e teste por ID.

3 · Homologação

Revisar evidências, riscos e exceções antes de qualquer implantação.

Hardening reduz a superfície de ataque; não garante invulnerabilidade.

Fontes: checklist de Gabriel Cortez e Rodrigo Campos; conversa/prints fornecidos.
Referências técnicas a verificar: Microsoft Learn / auditpol / secedit · NIST SP 800-63B-4 · gov.br/cisc.